

NARRATIVA EXPLICATIVA

El Sentido de Medir: GQM, PRAGMATIC y la Ciberseguridad Institucional en España

Kit GQM+PRAGMATIC FISMA 2025 — Documento (c) • Versión 1.0 • Abril 2026

"En el principio era el número. Pero el número sin propósito es ruido. El propósito sin número es poesía. La ciberseguridad necesita ambas cosas: la poesía de la estrategia y el número del dato. GQM + PRAGMATIC es, en el fondo, el intento más serio de que ambos se entiendan."

PARTE I: EL PROBLEMA — POR QUÉ LAS MÉTRICAS DE CIBERSEGURIDAD FALLAN

Hay un desorden muy específico que afecta a las organizaciones cuando intentan medir su ciberseguridad. No es falta de datos — hay datos en abundancia desbordante. No es falta de marcos — hay más marcos normativos que organismos capaces de auditarlos. El desorden es de otra naturaleza: es una **desconexión estructural entre lo que se mide y lo que importa**.

Se miden el número de parches aplicados, pero no si los sistemas vulnerables siguen expuestos. Se miden los cursos de formación completados, pero no si los empleados caen en los mismos trucos que en el ejercicio anterior. Se mide la existencia del Plan de Continuidad, pero no si alguien lo ha leído, y mucho menos si funcionaría en un incidente real a las tres de la madrugada de un domingo.

Este kit existe precisamente para atacar ese desorden desde dos flancos simultáneos. El primer flanco es **GQM** (*Goal-Question-Metric*): asegurar que cada métrica tiene un propósito trazable hasta los objetivos estratégicos nacionales. El segundo es **PRAGMATIC**: asegurar que cada métrica merece el esfuerzo de ser medida.

1.1 El Cementerio de las Métricas Huérfanas

En la mayoría de las organizaciones, las métricas de ciberseguridad nacen de uno de tres padres, ninguno particularmente fiable:

- El padre normativo: "Lo miden porque la auditoría ENS lo pide." Si el auditor deja de pedirlo, desaparece.
- El padre tecnológico: "Lo mide el SIEM porque viene configurado por defecto." Si cambian de proveedor, desaparece.
- El padre heroico: "Lo mide el antiguo CISO que creó el cuadro de mando en 2018." Cuando él se va, se convierte en un misterio que nadie entiende ni quiere tocar.

En los tres casos, la métrica no tiene raíces estratégicas. No responde a la pregunta fundamental de Basili: **¿por qué medimos esto?** Y si no hay respuesta a esa pregunta, el dato no tiene valor de gestión — solo tiene valor de decoración.

1.2 El Problema de la Legitimidad Métrica

El segundo problema es más sutil pero igualmente devastador. Supongamos que una organización decide medir el tiempo medio de aplicación de parches (CM-2). Excelente elección. Pero si nadie ha validado que ese dato es **genuino** (mide lo que dice medir), **preciso** (los sistemas legacy no están contabilizados), **independiente** (el equipo que parchea informa del tiempo a su jefe directo), y **rentable** (recopilar el dato manualmente consume 20 horas/mes del equipo), la métrica puede hacer más daño que bien. Genera una sensación de control que no corresponde a la realidad.

PRAGMATIC es, en ese sentido, una vacuna contra la falsa seguridad métrica. Sus nueve criterios no son caprichosos — son exactamente los nueve vectores por los que una métrica puede degenerar en desinformación institucionalizada.

PARTE II: LA SOLUCIÓN — GQM+PRAGMATIC COMO SISTEMA INTEGRADO

2.1 Cómo Funciona la Trazabilidad GQM en el Contexto Nacional Español

La **Estrategia Nacional de Ciberseguridad de España 2025** establece cinco ejes estratégicos que toda organización pública española debería poder trazar hasta sus métricas operativas. GQM+Strategies (Basili et al., 2014) proporciona el mecanismo formal para esa trazabilidad:

Eje 1 ENCS: Resiliencia de redes y sistemas → GOAL IX (IR) + GOAL X (CP)
Eje 2 ENCS: Capacitación → GOAL VII (Training) + GOAL I (Governance)
Eje 3 ENCS: Seguridad del ciberespacio → GOAL VIII (ISCM) + GOAL V (IDAM/ZTA)
Eje 4 ENCS: Marco institucional → GOAL I (Governance) + GOAL XI (Compliance)
Eje 5 ENCS: Capacidades industriales → GOAL II (C-SCRM) + GOAL VI (Data Prot.)

Esta trazabilidad tiene una consecuencia práctica inmediata: cuando un directivo pregunta "¿por qué medimos el tiempo de detección de incidentes?", la respuesta no es "porque lo pide la auditoría", sino "porque sin ese dato no podemos saber si estamos cumpliendo el Eje 1 de la Estrategia Nacional de Ciberseguridad — y porque sin Eje 1, no hay resiliencia institucional".

Esa es la diferencia entre una métrica con raíces y una métrica con fecha de caducidad.

2.2 El Sistema de Tres Preguntas que Salva una Métrica

Antes de adoptar cualquier métrica del catálogo FISMA FY2025, el responsable de medición debe responder tres preguntas:

Pregunta 1 — GQM: *¿A qué objetivo estratégico contribuye esta métrica?*

Si no hay respuesta clara, la métrica no debería adoptarse sin rediseño.

Pregunta 2 — PRAGMATIC criteria G + R: *¿Mide realmente lo que dice medir, y le importa a quien decide?*

Si la respuesta a cualquiera de las dos es "no", la métrica requiere revisión antes de producir datos.

Pregunta 3 — PRAGMATIC criteria A + C: *¿Qué acción concreta provoca un valor bajo, y el coste de medirla es razonable?*

Si no hay acción clara o el coste es prohibitivo, mejor no medirla hasta tener los recursos adecuados.

2.3 Los Cuatro Tipos de Métricas en el Kit

Una vez aplicados GQM y PRAGMATIC, las 25 métricas FISMA FY2025 se distribuyen en cuatro categorías de madurez de adopción:

Categoría A — Adopción inmediata (score ≥ 71 , acción clara):

CM-2, IDAM-1, ISCM-2, ISCM-3, IR-3, CM-3, IDAM-3, Gov-1, RA-2

Estas métricas están maduras para implementación directa. La infraestructura para medirlas existe o puede obtenerse con inversión moderada.

Categoría B — Adopción con adaptación (score 61-70, debilidades identificadas):

Gov-2, Gov-3, SCRM-1/2/3, RA-1/3, CM-1, IDAM-2, DP-2, ST-2, ISCM-1, IR-1/2, CP-1/2

Estas métricas son valiosas pero requieren mitigar la debilidad principal identificada en la Matriz PRAGMATIC antes de producir datos fiables.

Categoría C — Adopción en fase 2 (score ≤ 60 , requieren inversión o rediseño):

ZTA-S1, ZTA-S2, DP-1, ISCM-4

Métricas emergentes o costosas. Valiosas a largo plazo pero prematuras para organizaciones que aún no tienen consolidadas las métricas de Categoría A.

Categoría D — Complementar con métricas de resultado:

ST-1 (completar formación → añadir ST-2 como validación), CP-1 (plan documentado → añadir CP-2 como validación)

Ninguna métrica de proceso debería existir sin una métrica de resultado que la valide.

PARTE III: EL CONTEXTO ESPAÑOL — POR QUÉ ESTO IMPORTA AHORA

3.1 El Momento Regulatorio

España vive en 2026 un momento normativo de densidad inusual. El ENS (RD 311/2022) exige adecuación de todas las AAPP. La **Directiva NIS2** (2022/2555) está en proceso de transposición formal mediante el **Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad** (enero 2025), que cuando entre en vigor convertirá en obligaciones nacionales lo que hoy son recomendaciones europeas. Y encima de todo ello, el **CCN-CERT** reportó en 2025 un incremento del 293% en incidentes críticos respecto al año anterior.

Este escenario crea una tensión perfecta entre obligación normativa creciente y capacidad técnica institucional que, en muchas organizaciones, no ha crecido al mismo ritmo. El resultado es lo que los especialistas en gestión del riesgo llaman **compliance washing**: se documentan los controles, se aprueban las políticas, se realiza la formación obligatoria — y la superficie de ataque real no disminuye.

GQM + PRAGMATIC es el antídoto conceptual para el compliance washing. No porque sea más riguroso que otros marcos — sino porque es el único que pregunta explícitamente: **¿y esto sirve de algo?**

3.2 La Particularidad Territorial Española

Las **Comunidades Autónomas** y las **Administraciones Locales** presentan una heterogeneidad de madurez en ciberseguridad que los datos del INCIBE confirman año tras año: la brecha entre las CCAA con mayor y menor capacidad supera los 1.5 puntos en una escala de 5. Esta brecha no es solo técnica — es también de recursos, cultura organizacional y liderazgo.

El marco GQM+PRAGMATIC contribuye a resolver una parte de ese problema: al definir qué métricas son más rentables de implementar primero (Categoría A), y al priorizar aquellas con mayor ROI de medición, permite que organizaciones con recursos limitados tomen decisiones de inversión mejor fundamentadas que si simplemente intentasen cumplir todos los requisitos simultáneamente.

3.3 La Pregunta que este Kit No Puede Responder

Hay una pregunta que ningún marco de métricas puede responder por sí solo: **¿estamos realmente más seguros?** Las métricas miden proxies de la seguridad — incluso las más genuinas del catálogo (CM-2, IDAM-1) son correlatos del riesgo, no el riesgo mismo.

Esto no invalida el esfuerzo de medición; lo contextualiza. Las métricas bien diseñadas bajo GQM+PRAGMATIC no dicen "somos seguros". Dicen "somos más seguros que hace seis meses, en este dominio específico, según este criterio verificable". Esa modestia epistémica es, paradójicamente, su mayor virtud.

La alternativa — no medir, o medir mal — no hace a las organizaciones más seguras. Solo las hace más cómodamente ignorantes de su situación real.

PARTE IV: CÓMO USAR ESTE KIT EN LA PRÁCTICA

4.1 Para el CISO: El Primer Uso es el Más Difícil

La tentación al recibir este kit es usarlo para producir un informe. Resistir esa tentación.

El primer uso debe ser una conversación: con la dirección, sobre cuáles de los 10 objetivos GQM son realmente los objetivos de **esta** organización. No los de FISMA. No los del ENS. Los de **esta** organización, en este territorio, con estas capacidades y estos riesgos específicos.

Hasta que esa conversación no ocurra, cualquier métrica producida por el kit tendrá el problema de origen que describía la Sección 1.1: será huérfana. Tendrá datos, pero no tendrá propósito.

4.2 Para el Investigador: Validación del Instrumento

El marco GQM+PRAGMATIC que fundamenta este kit puede ser objeto de validación empírica. Los scores PRAGMATIC asignados en este documento son **juicios de experto** — no datos empíricos. Un programa de investigación que recopilase datos reales de implementación de estas métricas en una muestra representativa de AAPP españolas permitiría:

1. Comparar scores PRAGMATIC esperados vs. experimentados
2. Identificar qué métricas son sistemáticamente más costosas de implementar de lo previsto (criterio C)
3. Validar si los umbrales de efectividad propuestos son calibrados correctamente para el contexto español

Esta es la agenda de investigación que este kit abre, no cierra.

4.3 Para el Legislador o Policy-Maker: Una Reflexión Incómoda

Los marcos normativos (ENS, NIS2) definen **qué** debe medirse y con qué frecuencia. Lo que no definen es **cómo validar que las métricas requeridas son las métricas correctas**.

La evaluación PRAGMATIC de las métricas FISMA FY2025 muestra que incluso los indicadores diseñados por el estándar más riguroso del mundo presentan debilidades sistémicas en los criterios de Genuinidad (G) y Oportuno (T). Si esto ocurre en FISMA, cabe preguntarse con qué rigor se ha evaluado la calidad métrica de los indicadores requeridos por el ENS o por NIS2.

Esta no es una crítica a los marcos normativos — es una invitación a que los instrumentos de medición que las normas exigen sean objeto del mismo rigor científico que los estándares técnicos de seguridad. PRAGMATIC proporciona el método. Falta la voluntad institucional de aplicarlo.

EPÍLOGO: LO QUE UN NÚMERO PUEDE Y NO PUEDE HACER

Un MTTD de 72 horas no hace llorar a nadie. Un incidente que paraliza el sistema sanitario de una comunidad autónoma durante 4 días sí lo hace. La distancia entre esas dos realidades es exactamente el espacio que los marcos de métricas intentan colapsar — convertir el número abstracto en urgencia concreta, la estadística en decisión, el dato en acción.

GQM garantiza que el número tiene propósito. PRAGMATIC garantiza que el número es fiable. Ninguno de los dos garantiza que alguien actúe cuando el número es malo.

Esa última garantía depende de algo que no hay en ningún estándar: el criterio P+R+A que no es de PRAGMATIC sino de las organizaciones — **Propósito, Responsabilidad y Actitud** ante la evidencia.

El kit les da los números. Lo que hacen con ellos es, inevitablemente, una decisión humana.

Kit GQM+PRAGMATIC FISMA 2025 — Narrativa Explicativa · Versión 1.0 · Abril 2026

Basado en: Basili, Caldiera & Rombach (1994) "The Goal Question Metric Approach"; Brotby & Hinson (2013) "PRAGMATIC Security Metrics"; OMB M-25-04; ENS RD 311/2022; ENCS 2025; CCN-CERT Informe Ciberamenazas 2025